

Where we are

Live status against the four stages. Two commits pushed, the security floor in place, and the identity anchor built. Everything now waiting on one thing: a real database.

100 TESTS PASSING	9 BLOCKED ON DB	2 COMMITTS PUSHED	2 MIGRATIONS	0 LINT / TYPE ERRORS
----------------------	--------------------	-------------------------	-----------------	----------------------------

Stage 0 — Foundations

The security floor. Nothing user-visible; everything else stands on it.

0.1 – 0.5 Repository, privilege boundary, security primitives

DONE

✓ Own git repo, home directory ignored so KAFRIADA can never land in the Lucid HR repo – pushed to kafriadadev_backend

✓ Four PostgreSQL roles. **The app role cannot write the ledger**; only the money role can

✓ Audit log protected twice – grants stop the app, a trigger stops even the owner

✓ Role scope (`scope_kind` , `scope_id`) in the first migration – one of the three expensive-to-change decisions

✓ Argon2id with concurrency cap and timing equalisation; session tokens stored hashed; QR signatures versioned for rotation

✓ Config refuses to boot in production with docs on, DEBUG logs, open CORS, a test payment key, or app and money sharing a role

✓ CI: ruff, mypy strict, pytest, gitleaks, pip-audit, and a grep that fails the build if a withdrawal path ever appears

0.6 Deploy pipeline

BLOCKED

- ☐ Staging in Frankfurt, migrations as a gated release step — needs the Supabase connection string
- ☐ Sentry and tracing wired before there is anything to trace

Stage 1 — The identity spine

Ends when a real person holds a printed QR card that a stranger can scan.

1.1 The identity anchor

DONE

- ✓ Phone normalisation — **13 ways of writing a number reduce to one stored value**, which is what makes the unique constraint mean anything
- ✓ KUID type: immutable, uniqueness documented as (state, year, serial), rescues hand-typed input without ever producing a different valid KUID
- ✓ Jigawa and all 27 LGAs with permanent three-letter codes; only Birnin Kudu live
- ✓ Migration 0002 — locations, counter, athletes, career events. Database trigger makes the KUID immutable, not just the code

NEEDS SIGN-OFF BEFORE THE FIRST DRIVE

The 27 LGA codes are printed inside every KUID issued there and can never change. **The CEO and state coordinator should approve the list** before any card is handed out — changing one afterwards means athletes in the same town hold permanently different formats.

1.2 Access — sessions, roles, permission matrix

NEXT

- ☐ Session issue, verify, revoke, idle timeout — 30 min staff, 30 days athletes
- ☐ `can(user, permission, scope)` as a route dependency, deny by default
- ☐ Generated permission matrix test — every role against every route, **with a second tenant** so "manages a roster" cannot silently mean "manages every roster"
- ☐ Audit write on every state change

1.3 KUID minting

THEN

- ☐ The single atomic counter statement, hashing done *outside* the transaction
- ☐ Retry safety — a duplicate phone returns the existing KUID rather than minting a second
- ☐ **Burst test: 200 concurrent registrations**, asserting no duplicate and no gap

1.4 Registration, OTP, public profile, QR card

THEN

- ☐ Screens **AUT-01** to **AUT-05** — plain form POSTs, tested with JavaScript off
- ☐ OTP through the outbox, so a Termii outage queues rather than fails
- ☐ **PUB-01** public profile, edge-cacheable, silhouette until verified
- ☐ **ATH-03** printable QR card, signature generated server-side

Stages 2 and 3

Not started. Stage 2 is the money and does not get compressed.

BLOCK	STATUS	CONTAINS
2.1 Ledger & payments	NOT STARTED	Paystack initialise, the idempotent webhook, gross and fee as separate ledger lines, the amount check that stops a ₦10 payment buying a ₦2,500 badge
2.2 Media & verification	NOT STARTED	Private bucket, EXIF stripping, the verification state machine including <code>revoked</code> , the review queue
2.3 Outbox & jobs	NOT STARTED	Hourly reconciliation, 72-hour expiry, the nightly check that every wallet balances
2.4 Assisted payment & clubs	NOT STARTED	Coordinator pays with cash collected, receipt to the <i>athlete's</i> phone, daily caps; club registration and rosters
3 Launch readiness	NOT STARTED	NDPR consent records, the full permission sweep, the eight-point restore drill, the three dashboards, load test

What is blocking what

Three open items. Only the first stops me writing code.

1 — THE DATABASE, AND A PROMISE NOT YET PROVED

Nine tests are written and cannot run. They are the ones that **prove** the audit log cannot be tampered with and that the app role cannot write the ledger. Until a real PostgreSQL exists, those guarantees are argued rather than demonstrated — and they are the two the whole product rests on.

Needed: rotate the exposed keys, then paste the new connection string into `api/.env`. Ten minutes.

2 — THE SIGN-IN DECISION

Supabase Auth in the browser, or Supabase for passwords and codes with *our* session cookie on top. The second keeps instant revocation, which matters because coordinators handle cash on shared phones. Stage 1.2 starts either way, but building it twice would waste two days.

3 — PAPERWORK, STILL NOT STARTED

Paystack business verification needs current CAC registration and takes one to three weeks. Termii sender ID takes three to ten days. Neither blocks the build; both block launch. If the CAC registration is not current, that becomes the longest task on the entire project — and it is the one nobody has checked.

WHERE THE ESTIMATE STANDS

Stage 0 and the first slice of Stage 1 landed in a day, ahead of the plan's estimate. That does not move the finish line: **Stage 2 is the money and will not be compressed**, and the calendar is governed by the paperwork, not the code. The realistic gate remains 7–9 weeks of full attention, and closer to 12–14 if KAFRIADA gets three days a week rather than five.